MIESC

Multi-layer Intelligent Evaluation for Smart Contracts

YieldNest — Focused Triage Report

Target: yieldnest/yieldnest-protocol @ 034cd65 · Scope: src/ (own code; EigenLayer restaking)
Scan: 225 findings (5 High / 38 Med / 98 Low / 84 Info) · Triage verdict: 0/5 High exploitable
Date: 2026-10-27 · Prepared by: MIESC automated static analysis (Slither) + manual triage

PUBLIC

YieldNest — MIESC audit triage memo

Target: `yieldnest/yieldnest-protocol` @ `034cd65` · scope `src/` (own code; excl. `lib/`, `interfaces/`, `external/`, `testnet/`) **What it is:** EigenLayer-based restaking protocol — ynETH (native ETH LST) and ynEigen (LSD restaking), with staking nodes, validator registration, a withdrawal queue, and a rewards distributor. **Toolchain:** Foundry (solc 0.8.27, cancun, optimizer 200, no via_ir) + Slither 0.11.3, reusing forge build-info. **Scan:** 225 owned findings — **0 Critical / 5 High / 38 Medium / 98 Low / 84 Info**. **Reports:** `YieldNest_Audit_EN.pdf` (276 pp), `YieldNest_Auditoria_ES.pdf` (261 pp).

> Triage layer. **Nothing here is a bounty submission.** No PoC was submitted anywhere; any disclosure is the user's own action.

Headline

None of the 5 High findings is attacker-exploitable — all verified false positives by reading the real code. Four are `arbitrary-send-eth` on role-gated functions whose recipients are canonical or protocol-internal contracts; one is a `reentrancy-eth` that is actually CEI-ordered and structurally unreachable. Fourth mature-enough target in a row with 0 exploitable Highs.

High findings — per-site verdict (5/5 FP)

1. reentrancy-eth → FP · `PooledDepositsVault.finalizeDeposits` L58

Slither flags `ynETH.depositETH{value}(depositor)` (L68) with `balances[depositor]=0` as cross-function reentrancy. **Verified FP:** - Within each iteration the balance is zeroed **before** the external call

(`balances[depositor]=0` at L67, then `depositETH` at L68) — CEI-ordered. - `ynETH.depositETH{value}(depositor)` sends ETH to the trusted `ynETH` vault and mints shares **to the depositor**; it does not send ETH back to the depositor, so no attacker fallback is triggered. - The cross-function target `deposit()` **reverts once** `ynETH` **is set** (`if (address(ynETH) != address(0)) revert YnETHIsSet()`), and `finalizeDeposits` requires `ynETH` set — so `deposit()` is disabled during finalization. Re-entering `finalizeDeposits` for the same depositor hits `balances==0 → continue`. No exploitable path.

2-5. arbitrary-send-eth → FP (role-gated + trusted/canonical recipients)

Site	Why FP
`RewardsReceiver.transferETH` L83	`onlyRole(WITHDRAWER_ROLE)`. `to` is supplied by the trusted withdrawer role. Privileged, not attacker-reachable.
`RewardsDistributor.processRewards` L130/135	`assertBalanceUnchanged` invariant; sends to `ynETH` (trusted) and `feesReceiver`, which is admin-set (init + `onlyRole` setter L157). Not attacker-controlled.
`StakingNodesManager._registerValidator` L341	`internal`, reached only via `registerValidators` (`onlyRole(VALIDATOR_MANAGER_ROLE)` `nonReentrant`). ETH goes to the **canonical ETH2 deposit contract**.
`StakingNodesManager._processPrincipalWithdrawalForNode` L632/637/653	`internal`, reached only via `processPrincipalWithdrawals` (`onlyRole(WITHDRAWAL_MANAGER_ROLE)`). Recipients are protocol-internal (`ynETH`, `redemptionAssetsVault`, `consensusLayerReceiver`).

Medium (38) — class characterization (spot-checked)

Class	Count	Verdict
`unused-return`	15	Noise — returns intentionally ignored.
`reentrancy-no-eth`	12	Role-gated admin setters / guarded flows; benign.
`uninitialized-local`	10	Noise — locals assigned before use / default is intended.
`incorrect-equality`	1	Single accounting equality; low concern.

Low (98) / Info (84)

Low dominated by `calls-loop` (41) and benign/event reentrancy (51) — expected in a multi-node restaking protocol that iterates over staking nodes and validators. Info is mostly `naming-convention`

(60). Standard hygiene; none security-relevant on spot-check. The 4 `missing-zero-check` items are the only mild hardening nits.

Bottom line

- **No submittable bug** found by static scan + triage — fourth target in a row (Lombard, Doppler, Valantis STEX, YieldNest) with all raw Highs being false positives, now across LST/launchpad/AMM/restaking.
- The restaking surface is heavily role-gated (VALIDATOR_MANAGER / WITHDRAWAL_MANAGER / WITHDRAWER / STAKING_ADMIN) with canonical/internal ETH recipients, which is exactly why the scanner's `arbitrary-send-eth` and `reentrancy-eth` flags do not translate into exploitable issues.
- Honest limits: verdicts are from code reading (role gating, CEI, recipient immutability); no PoC was needed (no candidate surfaced).

Appendix — Evidence trail

- Full scan: `YieldNest_Audit_EN.pdf` (276 pp), `YieldNest_Auditoria_ES.pdf` (261 pp); raw: `yieldnest_security_results.json`.
- Toolchain: HTTPS submodule fetch → `forge build --build-info --skip test/script` (solc 0.8.27, cancun) → `slither . --foundry-ignore-compile --json`.
- Target pin: `yieldnest/yieldnest-protocol` @ `034cd65`.